IEEE Access
Multidisciplinary ⋮ Rapid Review ⋮ Open Access Journal

Digital Object Identifier

Limits of Metamorphic Testing for Object-Level Authorization: Temporal Reachability, Oracle Admissibility, and Measurement Resolution

QIULONG LIN[1,2] AND NANLEI CHEN[1,2]
[1]Yango University, Fuzhou 350015, China (e-mail: ubfbzu3@163.com)
[2]Sogang University, Seoul 04107, Republic of Korea

Corresponding author: Nanlei Chen (e-mail: ubfbzu3@163.com).

ABSTRACT Broken object-level authorization (BOLA) is the top-ranked API security risk, yet detecting it is an oracle problem: vulnerable and correct systems answer identically. Metamorphic testing is a leading technique for that problem in Web systems; for the relations we study, the predicates delegate the verdict to a *GUI-reachability model*—a crawl-time snapshot of what the interface permits. We instantiate the published relations as defined and drive constructed and real systems through crawl, out-of-band change, and execution. Three findings follow. (1) Access granted out of band after the crawl is reported as a *proven* violation—a *false proof*—in 8 of 8 constructed alarms, because an out-of-band grant fits only the wrong one of the predicate's two representations. (2) Repairing this with a readable, sound oracle that fully resolves the proposition leaves the metamorphic step adding no observed adjudication benefit over the direct consumer of the same oracle and outcome; the paired methods disagree on only 3 of 216 true-violation records, all favouring the plain request. (3) The reported specificity of 99.81% is not conditioned on a check that the reachability model equals the authorization state, and its denominator cannot register a scenario-uniform failure.
The findings come from a 576-record scenario/configuration study on a constructed system, together with a controlled cell study on Gitea 1.22.6, extended, with a methodological variation, to Gogs 0.14.3 and GitLab 17.11.7; an endogenous control holds final visibility fixed, and the published relations reproduce the false proof within the gated subset that fires.

INDEX TERMS BOLA/BFLA, false proof, metamorphic testing, object-level authorization, oracle problem, specificity measurement

I. INTRODUCTION

BROKEN object-level authorization (BOLA), first in the OWASP API Security Top 10 [1], is the failure to enforce, per object, that the authenticated subject is entitled to the object touched. Detecting it is an *oracle* problem: vulnerable and correct systems answer with the same success status. Metamorphic testing is an established approach to that oracle problem, and MST-wi [2] is a substantial system-agnostic instance for Web systems: 76 system-agnostic relations (MRs) over 55 Web-specific predicates, reported to detect 85% of vulnerabilities with specificity 99.81%.

This paper asks what happens to that claim when the asserted property is object-level authorization. The predicates do not express entitlement; they express what their authors call reachability—what "the functionality exposed by the user interface" permits—with the role-to-resource mapping "**not always available**" [2]. We take that sentence as premise, not discovery. Delegating adjudication to a reachability model makes the moment the model was read part of the specification, so we instantiate the predicates *as defined*—over a model recorded at crawl time—and drive the system through three phases: crawl, change authorization out of band, execute. The middle phase is the one the original evaluation does not exercise.

We ran a 576-record scenario/configuration study on a constructed system and a controlled study on Gitea 1.22.6, extended, with a methodological variation, to Gogs 0.14.3 and GitLab 17.11.7. We propose no mechanism. What survives is three findings, one per research question (Section VI).

Research questions and findings

(1) *Temporal (RQ1).* Does the crawl-time reachability model remain sound for authorization decisions after an out-of-band authorization change? No: the adjudication as designed produces *deterministic false proofs*—a legitimate access granted

out of band after the crawl is reported as a proven violation, at rate 1.00 on the constructed system and 0.40 on Gitea, because the predicate's two representations cannot describe an out-of-band grant. The error is a property of the *reading*, not of the system. (2) *Oracle (RQ2).* When a readable, sound authorization oracle fully resolves the proposition under test, does the metamorphic step add incremental adjudication information beyond the oracle and the request outcome? Not observably, within the evaluated scenarios: the step carries no additional decision-relevant information beyond what the oracle-plus-request pair already determines—an empirical premise about the evaluated relations, formalised as a conditional (Proposition 2)—and the paired methods disagree on only 3 records, all favoring `direct_observe` (false proofs 0 vs. 0, recall 0.50 vs. 0.49; a descriptive, point-estimate comparison, not a formal hypothesis test, no margin pre-specified, not domination). (3) *Measurement (RQ3).* Can an input-level specificity metric provide stable scenario-level resolution for a scenario-uniform failure? No: the reported specificity is not conditioned on an explicit check that the reachability model coincides with the authorization state, and its input-level denominator cannot register a class-uniform failure, which unaffected inputs can dilute arbitrarily (Proposition 1).

The native execution, the seeded target and the second implementation are support evidence for these findings, not further headline findings (Section VII).

The findings are not a claim that MST-wi is wrong: the reachability stand-in is announced by its authors and the predecessor design attributes its residual false alarms to crawler coverage [3]. Our contribution is a *security-testing characterization* of metamorphic testing for object-level authorization in Web/API systems, not a new detector, with three layers. Although the technique is general, every empirical claim is scoped to reachability-gated authorization relations in Web/API systems—a prevalent class of networked-application security flaws—and we state where the transfer stops. (1) *mechanistic*—the false-proof failure is located structurally, in *when* the reachability model was read rather than which objects are visible; (2) *fair-control ablation*—under a readable, sound oracle, a same-observable direct adjudicator shows the metamorphic step adds no measurable adjudication information beyond the oracle and the request outcome; and (3) *metric characterization*—a specific failure mode is identified in a published specificity figure, which is not conditioned on the reachability–authorization correspondence its interpretation assumes and whose input-level denominator cannot register a class-uniform failure. The evidence—the three-phase instantiation with internal controls (Section III), the scenario/configuration study (Section IV), the Gitea study with an endogenous control and a seeded-vulnerability positive control (Section V), and the source reading, the native execution of the library's own relations and the second implementation (Section VII)—supports these layers rather than standing as further headline claims.

II. BACKGROUND: THE PREDICATES IN QUESTION

For authorization there is no intrinsic oracle: vulnerable and correct executions both answer with success. Metamorphic testing replaces the absent oracle with a relation over multiple executions—and the relation is only as sound as the assumptions it needs, which for authorization are exactly the facts the oracle was supposed to supply. MST-wi [2], building on Mai et al. [3], crawls a per-user model of reachable URLs and contents, then checks MRs against that recorded model. In the artifact we inspected, the predicates guarding an authorization MR read either the recorded model directly (`cannotReachThroughGUI`, `userCanRetrieveContent`) or static subject properties; we call a predicate *GUI-derived* when its value is a function of the crawl.

Why the false proof is a design consequence, not a bug

Suppose a subject can reach an object at crawl time, so the record stores it as reachable. Afterwards an administrator grants the same subject access to a *further* object through a channel—an administrative endpoint or a share link—that a crawl of the subject's own interface never traverses. At execution the guard still reads the frozen record, finds the new object absent, and concludes the subject cannot reach it; the relation then treats the successful response as a violation. Every step is exactly as specified, so no guard is miswritten: the predicate's two representations—"reachable as recorded" and "not reachable as recorded"—cannot express "reachable, but only after the record was taken". More crawling does not remove the false proof, because the grant need not be visible through the subject's interface at all, and the reported specificity never registers it, because the error is a property of the adjudication's *reading moment* rather than of any single generated input. This is the mechanism the rest of the paper measures, and the reason we speak of a boundary of the specification rather than a defect of an implementation.

Two census figures frame what follows. Over the 76 catalog MRs, 38 (50.0%) gate on a GUI-derived or identity predicate, and only 14 (18.42%) are authorization-relevant by name or action—an upper bound, reported as a caveat; a full-text search for predicates reading the *state of an authorization artifact* (ownership, permission record, share) finds 0 occurrences. Within the examined vocabulary, then, the authorization MRs have no authorization-artifact state observable to decide on, and the reading moment enters the specification: if an entitlement changes after the crawl, the MR evaluates reachability against a world that no longer exists. This is a statement about what the relations *mean*; our experiments are built so that the crawl-time and live readings can be told apart.

III. PROTOCOL: A FAITHFUL THREE-PHASE INSTANTIATION

Two instruments carry distinct claims. The three-phase instantiation below carries the quantitative results of Sections IV and V; a direct execution of the library's own relations—source unmodified, with the build configuration

and a replay harness added—carries one qualitative claim, that the published code produces the false proof we predict (Section VII-B). Neither instrument is a benchmark: the standing scope and non-claims are collected in Section VIII, and neither yields a claim of detector accuracy.

Three phases

(A) *Crawl*: record, per subject and object, whether the subject can reach the object through the interface, and freeze that record—the model the predicates will consult. (B) *Change authorization out of band*: alter a (subject, object) entitlement through a channel outside the crawled interface; the frozen model is not updated, because the architecture has no mechanism to update it. (C) *Execute the MR* against the current state while the predicates consult the frozen model. Phase B is what the original evaluation does not exercise, and it is where the reachability stand-in can be wrong (Fig. 1).

Adjudicator variants and internal controls

A raw alarm becomes a verdict through an exception policy, and different policies are different methods: `raw` (the alarm itself, with no exception handling at all—this is the baseline any filter must be read against); **v1** (an *existence* filter: any sharing record on the object downgrades the alarm, regardless of whom it names or what it permits); **v2** (existence plus operation coverage: the record must cover the operation the MR triggered); **v3** (state-calibrated—consults a readable authorization introspection surface, abstains when none is readable); `degrade_all` (the floor: abstain on every alarm); `direct_only` (authorization surface only, access outcome ignored—a deliberately unfair control); and `direct_observe` (a succeeding plain request checked against the same readable surface). The last consumes the same observable quantity as the MR family and decides the negative result.

Ground truth

Every quantitative result names its ground-truth source, and it is never the detector under test: construction state for the constructed system and the scenario/configuration study; system-specific live re-probes of effective authorization (the per-system validation procedure is described in Section V) for Gitea, Gogs and GitLab; the pinned route tables for the grant census; and the seed list for the seeded target.

Scenarios and design cells

Seven scenarios separate the reasons an MR can misfire: no shared object (S1, S2); an in-band legitimate share visible in the framework log (S3); an unshared plain violation (S4); a read-only share plus a write violation (S5); an out-of-band share invisible to the framework log (S6); an out-of-band share plus a genuine violation (S7). They are crossed with 8 configurations defined by instantiation mode, enforcement correctness, channel visibility and introspection availability. The nominal cross is 7×8 combinations, but four are inadmissible: the two no-exception configurations (`V-noE3-vuln0`, `V-noE3-vuln1`) are undefined under the two out-of-band scenarios (S6, S7), where the legitimate-sharing exception does not apply. This leaves 52 admissible design cells.

Statistical treatment

The 576 records are not independent observations. Each admissible cell is expanded deterministically by the factors that are actually varied: 2 metamorphic relations (MR-002, MR-004), 3 exception-policy variants (raw, one level, two levels—the first deliberately thrown switch), and 2 reachability readings (the frozen crawl-time snapshot and the live execution-time state—the second deliberately thrown switch). The two relations do not both apply to every cell: only MR-002 applies under scenario S5, so 8 S5 cells carry one relation while the remaining 44 carry two. The record count is therefore

$$576 = 44 \cdot 2 \cdot 3 \cdot 2 + 8 \cdot 3 \cdot 2,$$

a deliberately unbalanced design—the per-cell multiplier differs by scenario. The records are therefore a fixed enumeration, not a sample: we report counts, rates and design-cell denominators, and we attach no inferential interval to any of them. Where a headline count has a small denominator we say so explicitly (the anchored rate, 2/2, is unstable by construction) and lead with the larger-denominator count of the same phenomenon. No conclusion rests on statistical significance. Where a comparison is paired—the ablation of Section IV-C—we report discordant-pair counts rather than an interval over a difference. The replication ceiling is explicit: one constructed system, 52 cells, 2 MRs, three real systems.

Tooling and code provenance

Development of the analysis scripts was assisted by an AI coding assistant (declared in the Declarations). Every script that assistant touched was reviewed, executed, and its output checked by the authors against the raw records; the released pipeline recomputes every reported scalar from those records, every table is generated by the pipeline, and the macro files and the two auto-generated tables share a single source of truth. No AI tool participated in the detection loop or in any adjudication.

IV. SYNTHETIC STUDY: WHERE THE ADJUDICATION GOES

This study supplies the evidence for Findings 1 and 3, and the ablation behind Finding 2; the findings themselves are stated in Section VI.

A. DEFINITIONS

Confusions are defined over the *verdict*: a *false proof* is the strict subset of false alarms promoted to `violation-proven`—an error the tool asserts as established. We also report the *detection-keep rate* (share of fired true violations still alarmed) and count only abstentions justified by an unreadable oracle.

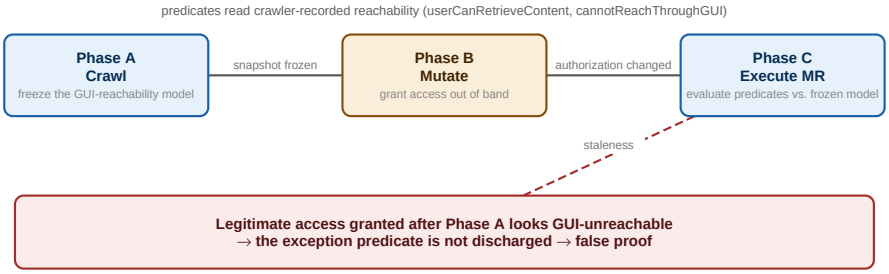


FIGURE 1. The three-phase instantiation. The predicates consult the reachability model frozen in Phase A. A Phase B entitlement change made outside the crawled interface leaves that model stale, so in Phase C a legitimately granted access has no representation but "cannot reach"; the exception predicate is not discharged and the alarm is promoted to a proven violation—the false proof of Finding 1.

B. WHAT THE CONSTRUCTED SYSTEM SHOWS

Attribution is clean

On the anchored configuration the false-proof rate is 2/2. With that denominator the rate is unstable by construction, so we attach to it no interval—nor a percentage, which would travel out of context. With the legitimate-sharing exception absent the rate is 0.00 (0/2), and with the channel listed it is 0.00 (0/2). The phenomenon is therefore attributable to a legitimate sharing exception the MR cannot know about, not to execution itself. A 2×2 grid over channel visibility and enforcement correctness tells the same story from the other side: on unlisted cells the false-proof rate is 44.44% with no false negatives; on listed cells it drops to 0.0% but one of the five violating records in that cell is a false negative (4 detected, 1 missed). Avoiding false proofs and keeping detection are controlled by one switch, and the switch cannot be thrown both ways at once.

Filtering exceptions does not help

The exception ladder—raw, one exception level, two—leaves the anchored rate at 1.00, 1.00, 1.00: it does not move. The exception levels we can express are themselves functions of the same reachability model, so they inherit its blind spot.

The framework cannot see the channel that matters

When a legitimate share was created through the framework's facility, its log holds 12 records and v2 produces 0 false proofs (rate 0.00); when the same share was created out of band, the log holds 0 records—no evidence the share exists—and v2's false proofs rise to 8 of 8 alarms (rate 1.00), every one promoted to `violation-proven`. The MR cannot distinguish "this share does not exist" from "this share exists but was not crawled"; its only representation of the first is the second. On S7, where a genuine violation *does* sit behind the out-of-band share, the same blindness makes the alarm right for the wrong reason (6 of 6 reached)—and that coincidence of alarms with violations is what an input-level metric cannot unpack. The same tension appears within a single MR: for S3 (must not alarm) vs S5 (must alarm), no configuration in the family is correct on both—the choice of switch is a choice of *which* error to make (Fig. 2).

Stratification, not aggregation

Aggregated, v3 looks best (recovery 1.00 against `degrade_all`'s keep rate 0.00); the reading is wrong, because v3 changes regime with oracle readability. Stratified over the 36-record readable grid and its 18-record absent grid (a representative grid; Section IV-E re-runs the same comparison over all 576 records): on the readable grid it removes v2's false proofs (0 vs. 4) while still alarming on all 9 fired true violations; on the absent grid (18) it alarms on none of the 5 true violations v2 still alarms on, abstaining 13 times. Pooling converts honest abstention into apparent performance, so v3's numbers may appear only stratified.

C. FAIR ABLATION: DOES THE METAMORPHIC STEP ADD ADJUDICATION INFORMATION?

Our earlier iteration proposed v3 as a mechanism, resting on the claim that the metamorphic step was necessary. We tested that claim by removing the step and substituting the most naive consumer of the same observable. The distinction matters: `direct_only`—oracle yes, access outcome ignored—produces 108 false proofs against v3's 0 (precision 0.50), and rejecting it proves nothing because it discards half the evidence. The fair control is `direct_observe`: a succeeding ordinary request plus the same readable surface, consuming exactly what the MR-based adjudicator consumes.

Table 1 concludes the ablation. The first three rows are a ladder, and they must be read in order: with no exception handling at all, `raw` yields 120 false proofs; the existence filter v1 cuts them to 60, but pays for it by abstaining on true violations (FN rises to 18); adding operation coverage (v2) restores the true violations (FN 3) at the same false-proof count. Neither filter is therefore a free improvement, and v3's zero in the FP column is bought with the FN column. `direct_observe` has 0 false proofs against v3's 0—a tie at zero, not a win. The comparison is paired, so we report the discordance rather than an inferential interval: over the 216 true-violation records the two methods disagree on 3, and on every one of them `direct_observe` is right—it detects a violation that v3 misses or abstains on, its reachability precondition blocking a detection the plain request makes. The aggregate recalls 0.50 and 0.49 restate that asymmetry

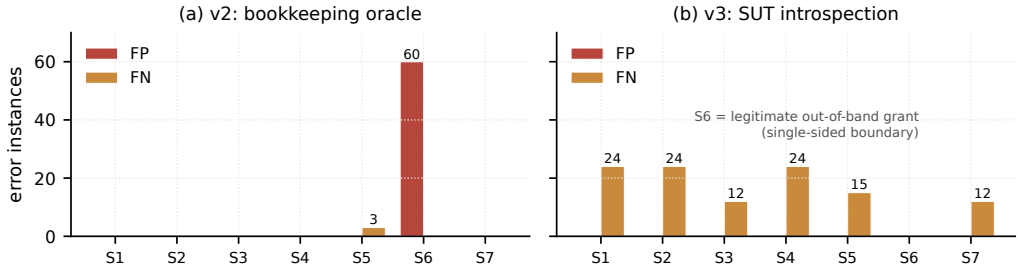


FIGURE 2. **The errors are scenario-structured. The bookkeeping oracle's false proofs concentrate on S6, the legitimate share created out of band and so invisible to the framework's own log, while the state-calibrated v3 abstains exactly where its surface is not readable. Both panels are recomputed from the same records as Table 1.**

TABLE 1. **End-to-end confusion matrix over all 576 records (216 true violations, 360 correct cases). The records are a fixed enumeration, not a sample (Section III, statistical treatment), so no inferential interval is attached; where a denominator is small we say so rather than interval it.** `direct_only` **is a deliberately unfair control, shown to make that point.**

method	TP	FP	FN	TN	precision	recall	F1
raw (no exception handling)	213	120	3	240	0.64	0.99	0.78
v1 (existence filter)	198	60	18	300	0.77	0.92	0.84
v2 (existence + coverage)	213	60	3	300	0.78	0.99	0.87
v3 (state-calibrated)	105	0	111	360	1.00	0.49	0.65
`degrade_all`	0	0	216	360	—	0.00	—
`direct_only`	108	108	108	252	0.50	0.50	0.50
`direct_observe`	108	0	108	360	1.00	0.50	0.67

rather than measure a difference, and no margin was prespecified, so no formal hypothesis-test claim attaches. We found no incremental adjudication advantage of the metamorphic step over direct observation in these oracle-available scenarios, and that absence provides no support for an incremental adjudication benefit in these scenarios: the step would have to be better at something the plain request cannot do. Selective presentation would have hidden the cost: v3's precision of 1.00 was bought with 111 false negatives (F1 0.65), an exchange of 60 false alarms for missed violations dressed as an improvement.

D. A PUBLISHED METRIC'S RESOLUTION: WHAT THE REPORTED SPECIFICITY DOES NOT CONDITION ON

The practical content of this finding is a diagnosis of a specific published figure, not a general property of ratios. Under the input-level specificity convention used by MST-wi [2], the reported specificity has the form

$$S_{\text{input}} = 1 - \frac{\text{false alarms}}{\text{inputs}},$$

and the figure of 99.81% is reported without an explicit check that the reachability model whose readings drive adjudication coincides with the true authorization state. Where the two diverge—the out-of-band case of Finding 1—the metric records agreement with the tool's own crawler rather than with entitlement, so a high value certifies the correspondence it silently assumes. The predecessor itself concedes the role-to-resource mapping is "not always available" and attributes its residual false alarms to crawler coverage of "all URLs for all users" [3]. The dilution below is elementary arithmetic, offered only to make the second half of the diagnosis—that the denominator cannot register a class-uniform failure—precise; we do not present it as the contribution.

We cannot reproduce the engine's exact input count, so we approximate two follow-up inputs per case—enough to exhibit the denominator's resolution, the only point at issue. In that approximation the configuration in which a whole class of legitimate access is misreported still yields a specificity of 0.85 (84.62%)[1].

A bounded formal remark on the denominator

Define $S_{\text{input}} = 1 - FP_{\text{inputs}}/N_{\text{inputs}}$ and $S_{\text{scenario}} = 1 - N_{\text{failed}}/N_{\text{scenarios}}$, where FP_{inputs} counts false alarms over all generated inputs and N_{failed} the scenarios in which the failure is uniform. S_{scenario} is introduced only as an analytical construct for characterising resolution; it is not proposed as a replacement evaluation metric. The remark concerns metric resolution, not estimator consistency or statistical power.

Proposition 1. Fix $f \geq 1$ failed scenarios, each producing a fixed number $a \geq 1$ of false-alarm inputs, and $s \geq 1$ successful scenarios each contributing m additional, alarm-free inputs. Then $S_{\text{input}} = 1 - (fa)/(fa + sm)$, which tends to

[1]This value is illustrative of the denominator's resolution only. It rests on an assumed two follow-up inputs per case, an approximation we cannot ground in the engine's exact input count; what matters is the *form* of the denominator, not the value.

1 as $m \to \infty$, while $S_{\text{scenario}} = 1 - f/(f+s)$ is independent of m and strictly less than 1.

Proof. $N_{\text{inputs}} = fa + sm$ and $FP_{\text{inputs}} = fa$; substitution gives $S_{\text{input}} = 1 - (fa)/(fa+sm) \to 1$ as $m \to \infty$, whereas the scenario-level figure depends only on the fixed counts f and s. □

Corollary 1. No fixed input-level specificity threshold $t < 1$ can guarantee that a scenario-uniform failure will push the metric below it: choosing $m > (fa/s) \cdot t/(1-t)$ drives S_{input} above t while the f failing scenarios remain failing.

The two halves of the finding are about the specific reported figure, not about ratios in the abstract: its value records agreement with the tool's own crawler where model and authorization state diverge, and its denominator cannot register a class-uniform failure even when one occurs.

Implementation robustness

An independently written implementation of the same predicates was compared on a subset fixed in advance; it bounds implementation accident only, and is reported with the confirmations in Section VII-C.

E. WHAT POOLING HID: THE ABLATION SPLIT BY ORACLE READABILITY

Table 1 pools two populations in which the oracle-consuming methods behave in opposite ways, and the pool is misleading in both directions. Section IV reports the comparison on a representative grid; this subsection, summarised in Table 2, repeats it over all 576 records. The records differ in one respect that decides whether those methods can act at all: whether the introspection surface returns a reading for the record. We therefore repeat the same comparison inside each stratum, with the same methods and the same decision rule, and we add two references that need no oracle against which the metamorphic family can be scored where no oracle exists.

Stratification variable

We stratify on the *effective* readability of the surface—the value the probe returns for the record—not on the configuration switch. The distinction is not cosmetic: 108 records sit in configurations flagged `introspection=on` whose surface nevertheless returns nothing (the two no-exception configurations), so the configuration flag is not a faithful proxy for whether an oracle was available to the adjudicator, and using it would misclassify those records. The two strata partition all 576 records: 312 readable, 264 unreadable. Both are fixed enumerations, so as elsewhere we report counts and rates and attach no inferential interval.

The readable stratum strengthens Finding 2

Splitting does not rescue the metamorphic step; it removes the comparison in which it looked best. On the 312 readable records `direct_observe` reaches recall 1.00 with 0 false proofs, against v2's recall 0.97 with 36 false proofs, and against v3's recall 0.97 with 0. The ordering is therefore not an artifact of the metric—the plain request is ahead on false proofs and not behind on detections—whereas the pooled table had let the family appear competitive on recall. We do not claim domination: the comparison rests on the constructed-observable argument of Proposition 2, and `direct_observe` is not an independent method here, since it is built from the same two quantities that define the reference (its second input, the access outcome, is part of how the reference labels a violation). What the split shows is the scope of the necessity claim: where an oracle resolves the proposition, there is nothing left for the relation to add, and the pooled numbers were flattering to the relation only because they mixed in records where the oracle-bearing methods could not run.

The unreadable stratum is the relation's own regime, and it is not empty

The 264 unreadable records contain 108 true violations and 156 correct cases, a violation base rate of 40.91%. Every oracle-bearing method—v3, `direct_observe`, `direct_only`—detects 0 of them, not because the relations are weak but because those methods have nothing to consult and, by their own definition, abstain. The metamorphic family does not abstain: v2 reaches all 108 true violations (recall 1.00) with 24 false proofs, precision 0.82, a lift of 2.000× over the base rate. Against the two no-oracle references: `always_alarm` scores precision 0.41, which is the base rate itself—no information at all—and `obs_success`, which alarms on the observed success of a plain request, reaches the *same* recall at precision 0.69, lift 1.692×. The net difference between the metamorphic family and that reference is therefore not in detections (0 additional true violations) but in false alarms: 24 fewer for the metamorphic family.

What the saving consists of

The attribution is one-sided and mechanical. Over the seven scenarios, every record of the 24-alarm saving falls on S3, the legitimate share created *through the framework's own facility* and hence recorded in its log: 24 false alarms for `obs_success` against 0 for v2 on the 48 records of that scenario. On S6, the same share created out of band, the two agree exactly (24 vs. 24 false alarms on 24 records), and both for the reason developed in Section VI-A—the predicate has no representation for a grant the crawl did not see. So the incremental detection information the metamorphic step carries where no oracle exists is exactly the information the crawl-derived reachability model can see: it suppresses what was logged, and it reproduces Finding 1 on what was not. This bounds Finding 2 rather than overturning it. Finding 2's antecedent—a readable, sound oracle that fully resolves the proposition—fails on this stratum by construction, and where it fails the relation is not worthless but worth precisely the reachability model it reads: above a trivial floor, above a single uninterpreted request, and below any method that can consult the entitlement.

TABLE 2. The ablation of Table 1 re-run inside each stratum. The two panels are not rankings of the same population but two different regimes: in the readable stratum the oracle-bearing methods can act; in the unreadable stratum they cannot act and are structurally bound to zero detections. The two reference rows need no oracle and no crawl model: `always_alarm` is the trivial floor, `obs_success` alarms on the observed success of a plain request. All numbers are counts.

stratum	method	TP	FP	FN	TN	precision	recall	F1
readable (312)	`raw`	105	72	3	132	0.59	0.97	0.74
	v1 (existence filter)	96	36	12	168	0.73	0.89	0.80
	v2 (existence+coverage)	105	36	3	168	0.74	0.97	0.84
	v3 (state-calibrated)	105	0	3	204	1.00	0.97	0.99
	`direct_observe`	108	0	0	204	1.00	1.00	1.00
	`obs_success`	108	96	0	108	0.53	1.00	0.69
	`always_alarm`	108	204	0	0	0.35	1.00	0.51
unreadable (264)	`raw`	108	48	0	108	0.69	1.00	0.82
	v1 (existence filter)	102	24	6	132	0.81	0.94	0.87
	v2 (existence+coverage)	108	24	0	132	0.82	1.00	0.90
	v3 (state-calibrated)	0	0	108	156	—	0.00	—
	`direct_observe`	0	0	108	156	—	0.00	—
	`obs_success`	108	48	0	108	0.69	1.00	0.82
	`always_alarm`	108	156	0	0	0.41	1.00	0.58

Limits of the comparison

Two references are deliberately weak, and we do not present them as the frontier of oracle-free detection: `obs_success` uses one request and no model, and a differential prober that compares several accounts against one another—the shape taken by the black-box line reviewed in Section IX—consumes more than `obs_success` does and was not instantiated here. The lift we measure is therefore an estimate against weak references, not a claim about metamorphic testing versus the best oracle-free detector, and we make no such claim. Both references also share an observable with the reference labelling (`obs_success` alarms on the same access outcome that partly defines a violation), so their absolute rates carry the same constructiveness caveat as `direct_observe`; only the differences are meant to be read. Everything here is one constructed system, one MR family, and one criterion (the alarm) rather than the promoted verdict.

V. REAL SYSTEMS: GITEA, GOGS, GITLAB, AND A SEEDED CONTROL

This section supplies the real-system evidence for Findings 1 and 2: the Gitea study with its endogenous control, the cross-vendor replication, and the seeded positive control (support evidence, Section VII).

A synthetic system cannot tell us whether the crawl-time reading is an artifact of our construction, so we repeated the essential comparison on real systems. We chose Gitea 1.22.6 for genuine object-level sharing with per-object visibility, a machine-readable sharing surface, and a documented administrative grant path. Three scope conditions, stated before the numbers. First, on the endpoints and authorization transitions exercised here, Gitea enforced the expected decisions: no instance of the studied vulnerability was found, so the experiment measures only the false-proof side. Second, the cell study uses our instantiation of the predicates, not the engine; the engine's own relations are executed separately in Section VII-B. Third, the reachability model is reported under *both* readings—crawl-time snapshot (what the definitions presuppose) and the live execution-time state—so the time at which the model was read can be isolated as the explanatory variable. The experiment produces 96 cells, 48 per reading.

TABLE 3. The grant surface of Gitea 1.22.6 (instance-independent).

quantity	count
paths in the system's API description	253
grant endpoints	15
of which usable without site-admin	8
revocation endpoints	2

Grant surface

Table 3 counts an endpoint as grant-capable if, without modifying the system, a request can move a (subject, object) pair from not-entitled to entitled. The 8 endpoints drivable by a non-administrator are the out-of-band channel in its real form: a subject who is not an administrator can create an entitlement that a crawl of that subject's own interface need not reveal. The cross-vendor table below reports a normalized census (semantically equivalent routes merged, non-authorization grant surface excluded), which is why its Gitea figure (13) differs from the raw count (15) here; the two answer different questions.

Is the authorization surface readable, and from where?

Readability depends entirely on the vantage, so the counts below are different populations and must not be read as one denominator. From the owner/administrator vantage the sharing surface is readable on 56 of 56 owner-vantage attempts over the 48 cells: complete. From a black-box subject's own vantage—the vantage a black-box tool occupies—it is readable on 0 of 40: never. An intermediate count of 16/56 comes only from subjects who happen to be owners or administrators and does not constrain the mechanism; it is not synonymous with "an arbitrary black-box subject can read the surface". Table 4 collects these populations. On 48 of 48 applicable cells the credential-substitution check confirmed that our model agrees with the system's behavior (Fig. 3).

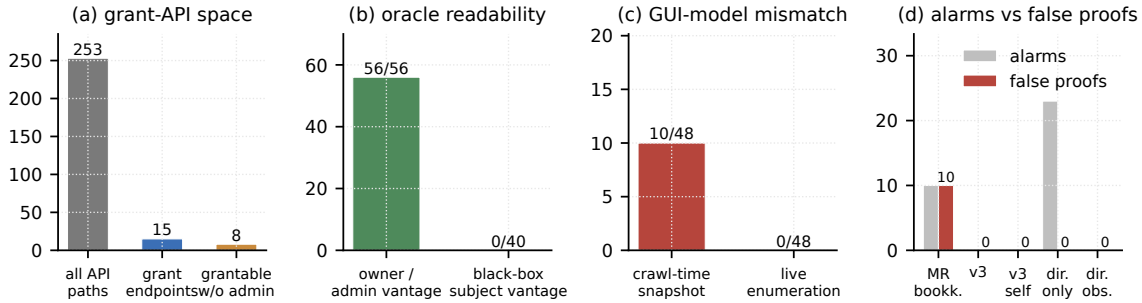


FIGURE 3. Gitea 1.22.6. (a) the grant-API space; (b) authorization-surface readability, complete from the owner/admin vantage (56/56) and never from a black-box subject's (0/40); (c) the departure from the real authorization state is present under the crawl-time reading (10/48) and absent live; (d) alarms versus false proofs per adjudicator. All counts are recomputed from the run records by the analysis pipeline.

TABLE 4. Authorization-introspection readability protocol on Gitea. Each row is a distinct population and denominator, so the rows are not comparable: both the vantage and the unit of the denominator differ.

vantage	attempts	readable
owner-vantage authorization-introspection surface	56	56
arbitrary subject (black box)	40	0
subject also owner/admin (representative grid)	56	16

Is the write path verified by state rather than status?

A status code cannot establish that a write took effect, so the write path is checked by content: the subject creates a uniquely named file, the owner re-reads it byte-for-byte as the ground truth, and the file is deleted where the API allows it. Across the 3 systems, 120 of 120 cross-credential write attempts agree with the ledger, with 0 unauthorized writes; no status code contradicted the content outcome (count: 0). The owner control—a non-admin writing its own repository—changed content in 24 of 24 attempts. On 2 of the 3 systems the site administrator could not write through the contents API although the ledger grants write; those 24 control rows are excluded from the cross-credential denominator and reported as a modelling gap rather than absorbed. Restore is unavailable on 1 of the 3 systems, whose contents API exposes no delete, so its probe files remain in a disposable instance.

The mismatch is in time, not in visibility

Table 5 is the load-bearing result: the adjudication departs from the real authorization state on 10 of 48 cells under the crawl-time reading and 0 of the same cells under the live reading. System state and tested relation were held fixed; only the time at which the reachability model was read changed. Under the crawl-time reading a bookkeeping adjudication produces 10 false proofs on the 25 authorized cells (rate 0.40), against 0 alarms live; v3 produces 0 false proofs, and `direct_observe` emits 0. The unfair control `direct_only` raises 23 alarms, more than any other adjudicator, simply because it ignores the request outcome; on this system none is promoted to `violation-proven`

TABLE 5. Departure from the real authorization state, per reading of the reachability model.

reading of the reachability model	mismatch	cells
crawl-time snapshot (as the definitions presuppose)	10	48
live execution-time state	0	48

TABLE 6. Endogenous control: two objects that are both public at the end.

object	cells	`cannotReach`	MR fires
public before the crawl	6	0	0
public only after the crawl	6	5	5

under our strict false-proof definition (0 false proofs), so alarm count and false-proof count are not the same quantity. Channel provenance of the authorized access (24 of 25 not observable by the framework log, 0.96; of these 11 are literal out-of-band grants and 13 implicit via site administration or public visibility) is a property of our topology—a design parameter, not a field prevalence.

An endogenous control

The most serious alternative explanation is that public objects are simply harder to enumerate—visibility, not time. Two objects that end equally public but became public at different moments control for this (Table 6): the predicate reports unreachability on 5 of 6 cells only for the object made public after the crawl, and on 0 for the object public throughout, with the MR firing correspondingly (5 vs. 0). Final visibility is identical, so within this design the only manipulated explanatory variable is when the model was read.

A. CROSS-VENDOR REPLICATION: GOGS 0.14.3 AND GITLAB 17.11.7

We repeated the same three-phase protocol and 48-cell design on two further systems (Table 7): **Gogs** 0.14.3, the project Gitea forked from in 2016 (related lineage, independently evolved code; census from its pinned route table, 80 paths), and **GitLab** 17.11.7 (no lineage; census from the pinned running instance's routes, 1357 paths, since its OpenAPI document omits core grant endpoints). Gogs is a replication

across implementations, GitLab across vendors within one domain.

The replication introduces a primary methodological variation: the authorization-introspection surface, which shows that *readability does not imply soundness*. Gitea's owner-vantage surface is readable and sound (agrees with effective access on all 48 cells). Gogs's collaborator-membership endpoint is equally readable (48/48) but unsound—wrong on 17 cells (35.4%), exactly the authorizations arising outside direct membership: site administration (8), public visibility (5), out-of-band grants (4). GitLab's `members/all/{u}` resolves inherited membership, but public visibility and site administration confer none: 18 false negatives (37.5%). What a surface cannot see is predictable from what it measures—why clause (2) of the admissibility condition (Section VI-D) cannot be automated from readability alone. The consequence is measurable: on Gitea the surface-gated adjudicators produced no false proofs (0 v3, 0 direct-observe), while on Gogs they manufacture them (8 snapshot, 5 live, 17 direct-observe) and on GitLab again (5, 18), every v3 false proof falling on a cell whose authorization derives from site administration or public visibility (8 and 5 such cells on Gogs; 8 and 10 on GitLab). A readable membership surface with a blind spot converts that blind spot into confirmed violations; no admissible oracle was available from the tested introspection surfaces on Gogs or GitLab, so the honest adjudicator abstains on the stratum where those surfaces would license a promotion.

Two results replicate everywhere: bookkeeping alarms false-proof on legitimately granted access (Gitea 10, Gogs 11, GitLab 10 cells) with the same out-of-band-dominant grant profile; and the reachability mismatch persists (Gitea 10, Gogs 19, GitLab 10 snapshot). On Gogs the mismatch only partially resolves live (13 remain—team or public grants never enter a subject's personal crawl); on GitLab the live reading recovers everything (0 remain)—a second, vendor-specific failure of the snapshot premise, in the crawl model rather than the oracle.

B. A SEEDED POSITIVE CONTROL

On the tested endpoints and transitions the three real systems enforce the expected decisions, so the question remains: *when a real object-level flaw is present, does the same detector find it?* We answer with a positive control. A *controlled authorization target* faithfully emulates the Gitea API contract the engine consumes, with a correct internal authorization model and 3 seeded vulnerable instances—all instantiating one fault pattern (a none-entitlement subject served the object at `GET /api/v1/repos/{owner}/{repo}`), differing in subject and object, not in fault location; Table 8 is therefore evidence about this fault pattern, not three independent defect discoveries. Two design points. The target deliberately exposes its authorization state to the subject-side harness (mirroring the admissibility condition), which production Gitea does not—there the oracle is readable from the owner/admin vantage (56/56) but not from an arbitrary subject's (0/40)—and its introspection surface reports the *correct* `none` permission, so the oracle stays sound and the defect is visible only as a discrepancy between oracle and request. We drove it with the same topology, mutation, crawl, introspection and adjudication code as above, differing only in the system under test; ground truth comes from the seed list, not from the detector.

Table 8 is consistent with the negative result of the ablation in this controlled fault pattern: `direct_observe` and `v3` catch all 3 planted instances with zero false positives, while `direct_only`, which ignores the request outcome, raises 30 alarms on cells where the surface says `none` and no access succeeds—alarms our strict definition does not promote. The control thus narrows the claim to one fault pattern: when a surface that fully resolves the authorization question is available, the metamorphic step is not necessary for detection here. It does not generalise beyond that pattern, and it also delimits the detector: we seeded one BFLA defect (non-privileged bob succeeding at `PUT .../collaborators/{u}`, HTTP 204), which the read-oriented logic does not cover—a known boundary, reported as such rather than as a detection failure. This is a controlled research artifact, not production Gitea; a sanity check on the detector's logic, not a validation of detection effectiveness on a population, and not a statement about Gitea's CVE posture. Its source, seed list and run script are in the reproducibility package at https://github.com/ubfbuz3/JISA (tag `artifact-v1`).

C. A PUBLICLY FIXED DEFECT

The seeded control is a controlled artifact, so we also ran one defect that nobody here planted: Gitea 1.20.5 against 1.20.6, the release whose notes record a security fix titled "Fix comment permissions" (`#28213`, backported as `#28216`); the same defect is catalogued as CVE-2023-49946 for Forgejo, the fork that reported it. What is missing is object ownership rather than path permission: a caller entitled to the repository named in the URL can address an object that belongs to a different, private repository.

Each version runs as a fresh instance, and the collision is built into the topology: alice owns a private repository with one issue comment, bob owns a public one. Bob sends `PATCH /api/v1/repos/bob/pub/issues/comments/{alice's comment id}` with a replacement body. On 1.20.5 the write succeeds (HTTP 200) and alice's own re-read returns the replacement body, so the effect is real and not a status-code artifact. On 1.20.6 the same request is refused (HTTP 404) and alice's re-read is unchanged (Table 9). The ledger gives bob no write channel on alice's repository (E = deny), so the vulnerable cell is a true positive under the definition used throughout, and the fixed cell raises no alarm: 1 true positive and 0 false proofs across the pair. All 12 control writes behave as expected in both versions—bob's own comment is editable, the correct path is refused, a third user is refused, anonymous is refused, an absent identifier is refused—and alice's restore returns the body to the original in 2 of 2 instances.

What this establishes is narrow, and worth stating plainly.

TABLE 7. Cross-vendor replication under the identical three-phase protocol (crawl, out-of-band authorization change, adjudicate) on Gitea 1.22.6, Gogs 0.14.3, and GitLab 17.11.7. Counts are per reading of the same 48-cell grid; the live reading is given in parentheses where both exist. The snapshot reading is the operating point of the published relations. Gitea and Gogs share lineage (fork, 2016); GitLab shares none. The team-derived row is read out of the per-system oracle false negatives by channel (Section V-A). The Gitea grant count here is the *normalised* M1 census (semantically equivalent routes merged, non-authorization grant surface excluded), and therefore differs from the raw route count in Table 3; the two tables use different normalisations and are not in conflict.

	Gitea 1.22.6	Gogs 0.14.3	GitLab 17.11.7
API entries in pinned version (M1 denominator)	253	80	1357
Grant endpoints (M1)	13	10	18
of which usable without site admin	10	4	17
Owner-vantage oracle readable	48	48	48
oracle agrees with actual access	48	31	30
oracle wrong (false negatives)	0	17	18
oracle wrong: team-derived access missed	0	4	0
Subject-vantage oracle readable	8	35	48
Reachability mismatch, snapshot (live)	10 (0)	19 (13)	10 (0)
False proofs: bookkeeping alarm, snapshot (live)	10 (0)	11 (5)	10 (0)
False proofs: v3 (oracle-gated), snapshot (live)	0 (0)	8 (5)	5 (0)
False proofs: direct-only (oracle only)	0 (0)	17 (17)	18 (18)
False proofs: direct-observe (oracle $\wedge$ request)	0 (0)	17 (17)	18 (18)

TABLE 8. Positive control: detection of 3 seeded vulnerable instances (one fault pattern). TP/FN/FP/TN are counted against the known seed, not against a model.

method	TP	FN	FP	TN
`mr_bookkeeping`	3	0	2	43
`v3` (owner vantage)	3	0	0	45
`v3` (subject vantage)	3	0	0	45
`direct_only`	3	0	30	15
`direct_observe`	3	0	0	45
`direct_observe` (subject)	3	0	0	45

TABLE 9. A publicly fixed defect (object-versus-path ownership). The verdict uses *E* from the ledger and *Y* from the owner's re-read, not the write status.

version	PATCH status	owner re-read	gate verdict
1.20.5 (vulnerable)	200	changed	true positive
1.20.6 (fixed)	404	unchanged	no claim

It shows that the E/Y gate can issue a correct violation claim and stops issuing it once the vendor fixes the defect, so the gate is not merely a false-alarm suppressor. It does not show that we can *find* such defects: the identifier is given, the defect is public and already fixed, and the exercise is a positive control for the gate, not a discovery. Nor is it an evaluation on a population—one defect, one fault pattern (object versus path ownership), one product line.

VI. FINDINGS, ADMISSIBILITY, AND FALSIFICATION

Each finding is a boundary on what the published relations can establish about object-level authorization—*temporal*, *oracle* and *measurement*—carried by the studies of Sections IV–V. The confirmations they rest on (the predicates read at source, the published relations executed on a real system, an independent implementation of the same predicates) introduce no further claim and are collected as support evidence in Section VII.

A. FINDING 1 (RQ1): DETERMINISTIC FALSE PROOFS—THE TEMPORAL BOUNDARY

Taken as published—raw alarms, or alarms filtered by bookkeeping exceptions—the adjudication reports a legitimate access granted out of band after the crawl as an already-established violation, in the direction forced by the two-valued predicate encoding. On the constructed system, rate 1.00 (8 of 8 alarms) against 0 for the same share created in band; on Gitea, 10 false proofs on 25 authorized cells (0.40) under the crawl-time reading, against 0 alarms live—objects, entitlements and predicates held fixed, only the reading time changed—so the error is a property of the *reading*, not of the system; the endogenous control (Table 6) holds final visibility fixed and isolates that moment. The direction is forced: the predicate has exactly two representations, and a grant created outside the crawled interface has no representation but "cannot reach". The predecessor attributes its residual false alarms to crawler coverage [3]; we add that the failure is a function of *when* the model was read, which makes the natural oracle-based repair available while showing no incremental adjudication benefit from the metamorphic step (Finding 2).

B. FINDING 2 (RQ2): THE METAMORPHIC STEP ADDS NO OBSERVED ADJUDICATION BENEFIT

If the false proofs of Finding 1 are removed by consulting a readable introspection surface, it is the oracle that carries the work: for the authorization relations and scenarios evaluated here, once the oracle fully resolves the authorization proposition under test, replacing the entire metamorphic step with a single ordinary request—one that consumes the same readable oracle and access outcome—provides no observed incremental adjudication benefit. We state the reason rather than present it as a discovered effect: its burden is an empirical premise about the evaluated relations, not an algebraic identity.

Proposition 2 (adjudication of the evaluated relations is or-

acle-determined). Let O be an authorization oracle that is *readable* (its answer can be obtained from the vantage in question) and *sound* (its answer equals the true permission), and let R be the observed outcome of an ordinary request. For the authorization relations and scenarios evaluated here—whose predicates read the crawl-time reachability model M and the response, and nothing else—once O is readable, sound and complete for the proposition under test, M supplies no decision-relevant authorization information that (O, R) does not already determine: agreement with the true state is redundant, and disagreement makes the verdict unsound (Finding 1). The verdict of the metamorphic family is therefore a function $f(O, R)$ of O and R alone, and any adjudicator of that form is extensionally equal to the direct consumer $D := f(O, R)$—the two are the same function applied to the same arguments. A metamorphic step can be *shown* to be necessary only by exhibiting an observable it consumes that the direct consumer does not.

Proof. The first clause is the empirical premise, established for these relations by source inspection (Section VII-A) and by the ablation (Section IV-C); the middle clause then follows because M enters the verdict only through (O, R), and the remainder is the observation that a function agrees pointwise with itself, the last sentence being its contrapositive. □

The proposition concerns *adjudication* information only. It does not imply that a metamorphic relation cannot improve input generation, search-space reduction, or execution efficiency: a relation may guide which requests are issued, or which gated subset is exercised, while carrying no verdict information beyond (O, R). It is a requirement on *claims*, not a verdict on metamorphic testing: it says only that a verdict computable from (O, R) cannot be shown to beat the direct consumer of (O, R).

Scope, quantified

The comparison above is pooled. Section IV-E re-runs it inside each stratum of effective oracle readability (Table 2) and thereby bounds the claim rather than widening it. Where the oracle is readable (312 records) the conclusion is stronger than ''no observed benefit'': the plain request carries fewer false proofs (0 vs. 36) and no fewer detections. Where it is not (264 records) the antecedent fails—there is no oracle to consult, and every oracle-bearing method detects nothing by construction—so the metamorphic family is compared against oracle-free references instead: it retains an advantage over a trivial floor and over a single uninterpreted request (2.000× vs. 1.692× over the base rate), and that advantage is exactly coextensive with what the crawl-derived model can see. Finding 2 is a claim about the regime its antecedent describes; it does not say the relations are worthless outside it.

Evidence: Table 1—0 false proofs vs. 0 (a tie at zero, not a win) over the 216 true-violation records. The comparison is paired, so we report the discordance rather than an inferential interval: the two methods disagree on 3 records, and on every one `direct_observe` is right—the aggregate recalls 0.50 and 0.49 restate that asymmetry rather than measure a difference, and no margin was fixed in advance. Gitea independently reproduces the zero-false-proof result (0 vs. 0), but not the same comparison, because the tested surface contains no seeded vulnerability; the cross-vendor systems (Section V-A) and the seeded control (Section V-B) complete the evidence. One qualification is part of the claim: the control is *constructed*, not discovered—`direct_observe` instantiates the direct-consumer construction D of Proposition 2, so the tie is the empirical face of the necessary condition, a statement about the definitions rather than a coincidental measurement.

C. FINDING 3 (RQ3): THE REPORTED SPECIFICITY IS NOT CONDITIONED ON THE CORRESPONDENCE IT ASSUMES

The reported 99.81% is a statement about a corpus of generated inputs; it is not conditioned on an explicit check that the reachability model coincides with the true authorization state, and its input-level denominator cannot provide stable scenario-level resolution for a scenario-uniform failure. The omission: adjudication is a function of the reachability model, so where model and true state diverge—the out-of-band case of Finding 1—the figure measures agreement with the tool's own crawler; the authors concede the mapping is ''not always available'' [2], but the number is reported without the condition. The denominator: a failure uniform across a scenario class contributes only as many false positives as that class emits inputs, and is diluted by the rest of the run (Proposition 1: in our approximation the configuration that misreports a whole class of legitimate access still scores 84.62%; Corollary 1: no fixed threshold can guarantee that such a class forces the metric below it). We are not saying the figure is false or the false positives misdiagnosed; the claim is that such a metric does not itself validate the reachability-to-authorization correspondence on which its interpretation depends, and that a class-uniform failure can be held above any fixed threshold by unaffected inputs.

D. ADMISSIBILITY, AND FALSIFICATION

Three properties must be kept apart. A surface is *readable* when its answer can be obtained from the vantage in question; *sound* when its answer equals the true authorization state; and *admissible*, for promotion to `violation-proven`, when (1) it is readable *and* (2) one can give a reason that it is not of the same kind as the defect under test—not itself a reachability artifact whose blind spot correlates with the blindness tested. Readability is what makes soundness usable, but it neither implies soundness nor confers admissibility: the owner-vantage authorization-introspection surface is readable on every cell in each system (48 Gitea, 48 Gogs, 48 GitLab), yet sound on Gitea alone—it agrees with effective access on 48, 31 and 30 of those cells respectively. The cross-vendor systems are therefore not cases of ''no oracle'': a readable membership surface exists on both, but it is unsound for the authorization channels exercised here, so it fails clause (2). Clause (2) is a per-system judgement and not automatable

from readability alone; the cross-vendor results make it concrete (Gogs and GitLab fail it; their adjudicators convert the blind spots into 8 and 5 false proofs). Where the condition holds, the honest method consumes the oracle directly and drops the relation; where it does not, the honest method abstains—as v3 does on the unreadable stratum, where the aggregate table would have ranked it best, a ranking that reflects abstention rather than improved detection.

Read together, the two findings bound what the technique's adjudication can yield for the authorization proposition studied. If the reachability stand-in is the only warrant and it is wrong, a legitimate access becomes a false proof (Finding 1). If a readable, sound oracle is instead available, the relation adds no adjudication over the direct consumer of that oracle and the outcome (Finding 2). And where no readable, admissible oracle exists—the black-box case—there is nothing for a sound method to consume, so it abstains rather than proves. Across the statuses the oracle can take, the outcomes the evaluated relations can yield are thus a false proof, a result no better than the plain request (and, where the oracle is readable, worse), or an abstention; adjudication of a genuinely illegal access is not among them for these relations.

Each finding would fall as follows: Finding 1, if the predicates were defined over live rather than recorded reachability; Finding 2, by an authorization MR needing an observable that a succeeding request plus a readable oracle cannot produce; Finding 3, by a specificity in scenario units, or with the condition explicit, that still fails to separate the configurations studied here.

VII. SUPPORT EVIDENCE

Nothing here is a further finding. This section holds what the three findings rest on: the semantics of the two governing predicates read at source (Section VII-A), an execution of the published relations on a real system (Section VII-B), and the robustness of our numbers to a second, independent implementation of the same predicates (Section VII-C); the seeded positive control (Section V-B) and the cross-vendor replication (Section V-A) are the remaining confirmations and stay with the study that produced them. Each item is a confirmation of a mechanism already stated, not a new claim about what the technique can detect.

A. CONFIRMATION AT SOURCE

Definitions can be read generously, so we checked the predicates at source in the public library [2]. It ships 23 relations, 11 authorization relations, 8 gating on the two predicates analyzed. Four implementation-level properties not made explicit in the main presentation: (1) *the freeze is hard-coded*—`cannotReachThroughGUI` is set-membership over the crawl inputs, issues no request, and is cached in a field written once and never invalidated (`userCanRetrieveContent` likewise reads a crawl-produced store loaded once); (2) *the clause that could have caught it is inert*—the "absent across all users" set is built by stopping each recorded sequence at the first login action, so it is always empty; (3) *missing data defaults to an alarm*—with an empty or null crawl argument the predicate returns "cannot reach", so an empty crawl *satisfies* the precondition: the mechanism behind Finding 1's deterministic direction; (4) *the role relation is configuration, not state*—the supervisor guard reads a static configuration file and reports true for identical accounts, so it cannot reflect a later grant.

TABLE 10. Execution facts for the native run of the published relations (Section VII-B). All values are emitted by `ingest_native_engine.py` from the run record; upstream Java sources are unchanged apart from the build configuration.

item	value
authorization relations: catalogue, executed, fired	11, 10, 2
engine alarms (the engine's own return value)	6
HTTP requests attributed to observing relations	270
changed upstream Java sources	0
build/config changes (one `pom.xml` line)	1
added harness classes / added lines	two / 612

B. EXECUTING THE PUBLISHED RELATIONS

The library ships relations but no execution environment; we supplied the system configuration and crawl snapshot and ran the relations—source unmodified, build configuration (`pom.xml`) and an external harness added (1 changed upstream file, 0 changed Java sources, two added classes totalling 612 lines)—against Gitea 1.22.6 (Table 10). 10 of 11 authorization relations executed; 2 returned failures, 6 alarms in all—the engine's own `getFailures()` value (Table 12). What the run establishes is scoped to the *reachability-gated subset that fires here*, not a full replay of the catalogue: one relation aborts on an engine-side defect, most issue no request because their own guards are unsatisfied, and the content predicate is never invoked. Almost none of the 1483.7 seconds is analysis: each leaf evaluation invokes a browser-cleanup hook costing minutes, a cost of the missing environment that bounds any reproduction.

The load-bearing cell: the subject bob holds a legitimate entitlement to alice/s1, granted out of band after the crawl. There the published `cannotReachThroughGUI` answers "cannot reach"—the answer it is *defined* to give, since the subject's crawl record has no entry for the repository; across the run it answered so 1149 of 7321 invocations (15.7%), 5 on this cell, and 2 relations (OTG_AUTHZ_002, OTG_AUTHZ_002c) report a failure there. The access is authorized: all 3 granted cells were re-probed, and the grantee's response hashes identically to the owner's while a third account is refused. The 6 alarms fall on 3 cells, all post-crawl grants, none on a non-entitled object. Limits: the harness's HTTP observation channel is exact for the reachability predicate (set-membership, no request) but unexercised for the content predicate (0 invocations; supervisor guard 8642, 1321 true); not all gated relations fire, for reasons inside their own guards, and 1 abort on an engine-side defect—so the reproduced false proof is that of the reachability-gated subset that

TABLE 11. The native alarms split into the three stages: *A* (the engine's own `getFailures()`), *H* (the promotion policy *P* applied to *A*), and *T* (independent truth from the ledger *E* and the content re-read *Y*). Every row is an alarm, so *A* is not repeated as a column; *H* likewise applies to every row. † responder bytes identical to the owner's (sha256) and a third account refused with 404. MR names abbreviate `OTG_AUTHZ_`*x*.

MR	subject	object	*E*	*Y*	*T*
002	frank	acme/t1	allow	allow†	false proof
002	bob	alice/s1	allow	allow†	false proof
002	eve	carol/s1	allow	allow†	false proof
002c	frank	acme/t1	allow	allow†	false proof
002c	bob	alice/s1	allow	allow†	false proof
002c	eve	carol/s1	allow	allow†	false proof

fires, not a full-replay count of the published relations. And Gitea, on the tested surface, enforces the expected decisions, so the run can only exhibit false proofs.

Which stage of that claim does the native run establish?

Three stages have to be kept apart, and only the third is a security finding. The *native alarm A* is what the engine itself returns: `getFailures()` is appended by `MR.fail()` (`MR.java`:909), which logs `FAILURE` together with the failing input pair and asserts nothing about authorization—no ledger, no expected decision, no verdict. Reading a fired authorization relation as a *violation claim H* is a promotion policy *P* that we state rather than inherit: *P* maps every fired `OTG_AUTHZ` relation to "a violation was observed", which is the reading the catalogue's purpose invites but its code does not perform. Since *P* applies to every alarm, $H = 6$ holds by construction and carries no empirical content. All of it is in the independent truth *T*, computed from the ledger grant (*E*) and a content re-read (*Y*: the responder's bytes are identical to the owner's and a third account is refused): 0 violations are confirmed and 6 of the 6 promoted alarms are contradicted, on 3 cells (Table 11). A reader who declines *P* should read the run as 6 failed metamorphic relations rather than as 6 vulnerabilities; the disagreement survives that reading, because the failures fall on accesses the ledger allows.

C. IMPLEMENTATION ROBUSTNESS

An independently written implementation of the same predicates was compared with the main one on a subset fixed before the comparison, not sampled after it: the in-band scenarios on which a second reading is defined, holding the exception-policy variant at the representative level and the reachability reading at the one each relation uses (MR-002 blind, MR-004 aware). This yields 30 (configuration, scenario) points; MR-002 is defined on 30 of the resulting relation comparisons and MR-004 on the remaining 24, giving 54 in all. The two agreed on 54 of them (1.00); the point set is a fixed enumeration, so no interval is attached. Both were written from the same reading of the semantics, so this bounds implementation accident only; it does not bound a shared blind spot, and we do not present it as corroboration.

VIII. THREATS TO VALIDITY

Source versus execution

We read the predicates at source (built under JDK 8 and Maven; Section VII-A) and then executed the relations, unmodified apart from the build configuration and our harness (Section VII-B). The harness substitutes an HTTP observation channel—exact for the reachability predicate, not exercised for the content predicate, whose invocation count we report rather than claim cleanliness we did not demonstrate. The run converts one class of claim (the false proof is produced by the *published* relations on a real system); it does not convert the rest: the scenario/configuration and cell studies remain statements about our instantiation, our exception vocabulary belongs to the same predicate family, and we report no sensitivity or specificity attributable to MST-wi.

Metric and statistics

The specificity approximation uses two follow-up inputs per case—not the engine's count; the conclusion about the denominator's resolution does not depend on the exact value. Records within a design cell are not independent (Section III, statistical treatment) and the records are a fixed enumeration, so we report counts and rates rather than inferential intervals, and no result rests on statistical significance. The RQ2 ablation is paired and is reported as a discordance count.

Two MRs, one family

We instantiated 2 MRs of one family—relations gated on the absence of evidence. The native run lifts the count to 10 of 11 catalog authorization relations but not the family: only the reachability-gated ones alarm in our run. This is the paper's single most important limitation; raising it requires relations gated otherwise, a different experiment.

Real systems

Three systems (one lineage pair, one independent), chosen for accessibility, none vulnerable on the tested surface—so only the false-proof side is measured, within one domain, the git forge. Channel proportions are topology design parameters, not field prevalence. Constructed scenarios with construction-defined ground truth are why the real-system section exists; three systems tested once each are still not a population.

Stratification and the references used in it

The split of Section IV-E is on whether the introspection surface returned a reading for the record, not on the configuration switch: 108 records sit in configurations that enable introspection but whose probe returns nothing, so the switch would misclassify them. The two oracle-free references there are deliberately weak—one unconditional, one guessing from a single request—because the point is to size the metamorphic step against methods that need nothing, not to identify the best oracle-free detector; a differential prober across accounts consumes more than those references do and was not instantiated. Both references share an observable with the labelling rule, as `direct_observe` does, so only the differences against them—not their absolute rates—are meant to be read.

TABLE 12. The published authorization relations executed against Gitea 1.22.6. Each row is the applicability chain from the catalogue to the outcome: *status* is the engine's per-relation result (10 of 11 evaluated, 1 aborted on an engine-side defect), *alarms* its own `getFailures()` return (2 relations, 6 in all), and *requests* (270 total) attributed to the relation observing them first.

MR	status	alarms	requests
OTG_AUTHZ_001	executed	0	0
OTG_AUTHZ_001b	executed	0	0
OTG_AUTHZ_001b2	executed	0	0
OTG_AUTHZ_002	executed	3	270
OTG_AUTHZ_002a	executed	0	0
OTG_AUTHZ_002b	executed	0	0
OTG_AUTHZ_002c	executed	3	0
OTG_AUTHZ_002d	executed	0	0
OTG_AUTHZ_002e	error	—	—
OTG_AUTHZ_003	executed	0	0
OTG_AUTHZ_004	executed	0	0

Our own earlier claims

An earlier iteration proposed v3 as a mechanism on the strength of its precision (1.00), which was bought with 111 false negatives, and a control (`direct_only`, precision 0.50) that discarded the access result. Replacing it with a fair control produced the negative result. We record this as the condition any similar claim must meet: a control consuming the same observable quantity as the ground truth.

IX. RELATED WORK

Metamorphic security testing

Metamorphic testing was brought to web security by Mai et al. [3], who cast security test patterns—authentication, authorization, session—as metamorphic relations so that faults can be exposed without an oracle. The line matured into MST-wi [2], whose 76 system-agnostic relations over a Web-specific domain language are the object of our study. We take the technique's own admission that the role-to-resource mapping is ''not always available'' at face value and follow it to its consequence for what the adjudication can decide. A relation whose guard reads a crawl-time model is sound only while the model equals the authorization state, and that equality is exactly what the technique cannot check for itself.

Detecting broken access control

A large and active literature detects access-control flaws directly, and it is worth separating the oracles it relies on. Black-box probing drives requests with and without the rights of another subject and looks for a missing refusal [4], [5], a line that runs back to AUTHSCOPE [6] and that has been extended to deployed systems under ethical constraints [7]; where an API description is available, the oracle itself can be synthesised, for instance by transforming an OpenAPI specification into a colored Petri net that predicts per-object access [8]. A complementary, white-box line recovers the *enforced* policy from the implementation—by reverse-engineering RBAC policies [9], by statically extracting authorization policies [10] or database access-control rules [11], or by locating the permission checks themselves [12]—and then flags violations against that recovered model: BOLA in database-backed applications [13], missing-owner-check and function-level flaws in Java web applications [14], [15], function- and object-level access-control flaws across Web applications [16], and privilege escalation in polyglot microservices [17]. Specification-driven API fuzzers generate the requests well but inherit the same oracle difficulty [18]–[20]; adding explicit access-policy violation checks [21] moves them toward the detection problem but does not remove the need for a ground truth, and a recent turn delegates generation or probing to language models [22]–[24]. A concurrent line reframes BOLA under a zero-trust model, in which each request must carry an explicit authorization decision rather than one inferred from endpoint reachability [25]; our question sits at that decision level, asking what an oracle-substituting technique can establish about it. Our question is orthogonal to all of these. Each reports detections against an oracle it holds privately—a policy, a seeded defect, a differential response; we ask what an existing oracle-substituting technique *decides* when the entitlement information it needs is not among its observables, and we make that a measurable property of the technique rather than of a system.

Direct authorization oracles, and what is at stake here

Comparing responses across principals or privilege states is an established way to obtain an authorization oracle when the ground-truth relation is available, and the black-box and white-box lines above are instances of it. We propose no new direct oracle, and we do not claim that direct authorization comparison is novel. Our subject is a different question: what an existing oracle-substituting technique *decides* when it substitutes reachability for entitlement. The direct oracle enters our design in exactly one role—as the fair, same-observable control that a necessity claim about the metamorphic step must face. Without such a control, a substitution can appear necessary only because the alternative it is compared against was not allowed to consume the same decision-relevant observables.

LLMs and the oracle problem

LLMs are used for vulnerability detection and specification inference [26]–[29], including lightweight models over hybrid code features [30] and federated, explainable detec-

tors [31]; we use none in the detection loop. The transferable condition this paper exposes is that any claim of necessity must be tested against a fair substitute that consumes the same observable quantity as the ground truth.

Measurement and evaluation

Our contribution is finally a measurement, and it connects to work on the quality of the artifacts security studies are built on—for instance the observation that vulnerability datasets are frequently mislabeled, duplicated or otherwise unfit for the claims drawn from them [32]. The artifact we report is of the same family but inside a study rather than a dataset: a specificity figure whose *denominator* is structurally unable to register a whole class of failure, and whose operating point silently assumes a reachability model equals the authorization state. We therefore read a testing technique's own reported metric as a measurement instrument, stating explicitly what its denominator can and cannot resolve.

X. CONCLUSION

For object-level authorization, MST-wi's predicates do not know whether the acting subject is entitled to the object; they know what the interface, as crawled, permitted. Instantiating them as defined produced three findings (Section VI).

Finding 1 (temporal)

As designed, the adjudication false-proofs on legitimately granted access, deterministically (1.00 constructed; 0.40 Gitea), because an out-of-band grant fits only the wrong one of the predicate's two representations. On the real system the mismatch appears only under the crawl-time reading (10/48, vs. 0 live), with an endogenous control holding final visibility fixed: within this controlled design the only manipulated explanatory variable is when the model was read, not what was visible.

Finding 2 (oracle)

The natural repair—a readable, sound authorization oracle that fully resolves the proposition under test—works, and in that regime the evaluated metamorphic step provides no observed incremental adjudication benefit over a direct consumer of the same oracle and outcome: an empirical premise, formalised as a conditional (Proposition 2), whose empirical face is that a single ordinary request yields the same false-proof count (false proofs 0 vs. 0), and that of the 216 true-violation records the paired comparison disagrees on only 3, each time in favor of the plain request; no margin was pre-specified, so no inferential claim attaches. On Gitea the comparison is limited to false-proof behavior, because no vulnerability was present on the tested surface.

Finding 3 (measurement)

The reported specificity of 99.81% is diagnosed as a specific published figure: it is not conditioned on an explicit check that the reachability model equals the authorization state, and its input-level denominator cannot register a class-uniform failure.

Support evidence: reading the implementation confirmed the semantics and added the mechanism—the crawl model is frozen by a cache never invalidated, and a missing crawl defaults to ''unreachable''—and the positive control is a sanity check that closes the loop: on a seeded vulnerable target, for one fault pattern, the surface-gated adjudicator detects all planted instances with zero false positives.

What we do not claim, and how far the claims reach

We do not claim that MST-wi is wrong or say anything about its accuracy as a detector; the native run establishes a qualitative outcome, for one gate family, on one real system that on the tested endpoints and transitions enforces the expected decisions. Three ceilings stack and bound everything above. First, our two relations are two of a catalogue of 76, and both belong to one reachability-gated family. Second, even the execution of the published relations on the native engine reaches only that family: 2 of the 11 authorization relations fire (10 executed; OTG_AUTHZ_002, OTG_AUTHZ_002c), and the content predicate `userCanRetrieveContent` is never invoked (0 calls), so that evidence is bounded the same way. Third, the real-system study exercises the *false-proof* face on a single constructed fault pattern, not the detection face against a population of real flaws, and the Gitea channel proportions are topology design parameters, not field prevalence. Together these fix the ceiling on what a practitioner may transfer.

What a practitioner should do differently

Three operational consequences follow, each bounded by what was measured. Do not read a reachability-gated relation's alarm as proof: because the reading time is part of the specification, an alarm raised against a crawl-time snapshot—rather than against live state—cannot be promoted to `violation-proven` on the relation's word alone. If a readable, sound authorization oracle is in fact available to the analyst, consult it directly and drop the relation: for the relations studied it adds no adjudication information once that antecedent holds (Proposition 2, Section IV-E). And treat a reported input-level specificity as a corpus statistic rather than a guarantee of scenario-level resolution: it can sit near one while a whole class of legitimate access is misreported (Finding 3). These are not a claim that metamorphic testing is worthless; they locate its contribution where no oracle exists, and bound it by what the reachability reading can see.

What a stronger claim would require

Moving from characterization to something stronger needs, first, a real system that *contains* the flaw, so detection can be measured; and second, relations whose gate is not the absence of evidence—checkable against a subject's entitlements without pretending that entitlements are reachable facts. The transferable condition—we call it the *same-observable condition*—is the one that killed our own mechanism: a component's necessity must be tested against a substitute that consumes the *same* observable quantity as the ground truth; a substitute that consumes less does not establish incremental

value. The MST-wi case study is an instance of that condition, not its scope: a component's necessity is not established unless a fair control that lacks the component but consumes the same decision-relevant observables is empirically or formally shown to be weaker.

DECLARATIONS

DATA AVAILABILITY

The raw records of the studies reported here are publicly available under the version-pinned snapshot `artifact-v1` of the companion repository https://github.com/ubfbuz3/JISA (re-anchored to the submission commit): (1) the scenario/configuration study (`experiments/results/raw_matrix.jsonl`, `ablation_direct*.json`, `alt_matrix.jsonl`); (2) the real-system cell study across Gitea 1.22.6, Gogs 0.14.3 and GitLab 17.11.7 (`experiments/real_system/results/*.json`); (3) the execution of the published relations on the native engine (`experiments/native_engine/results/*.json`); (4) the seeded positive control (`seeded.json`). The analysis pipeline (`analysis/*.py`: `compute_all.py` and the ingest scripts) recomputes every number, table and figure in this paper from those records; the stratified ablation of Section IV-E adds no new experiment—it re-aggregates the same scenario/configuration records by whether the introspection surface returned a reading, and is recomputed, together with every macro it defines, by `ingest_m2_stratum.py`; `check_macro_use.py` asserts that every macro cited in the manuscript has exactly one definition. Running `bash reproduce.sh` regenerates all outputs and the PDF, and `bash verify_artifact.sh` asserts the SHA-256 integrity of every raw record and byte-reproducible output. The manuscript LaTeX source ships in the same repository. A persistent archival copy with a citable DOI is deposited at Zenodo: https://doi.org/10.5281/zenodo.22859942.

COMPETING INTERESTS

The authors declare no competing interests, financial or otherwise.

FUNDING

This research received no specific grant from any funding agency in the public, commercial, or not-for-profit sectors.

AUTHORS' CONTRIBUTIONS

Both authors contributed to the work. Qiulong Lin and Nanlei Chen jointly developed the conceptualisation and methodology, designed and implemented the software and analysis pipeline, carried out the investigation and formal analysis, and wrote the manuscript.

ETHICS

Not applicable. This study involved no human participants, no personal data, and no animals. All experiments were performed against software systems that we deployed and controlled locally.

DECLARATION OF GENERATIVE AI AND AI-ASSISTED TECHNOLOGIES IN THE WRITING PROCESS

During the preparation of this work the authors used Claude (Anthropic) to assist with literature verification, the development of the analysis scripts, and language editing. Where it contributed to analysis code, every generated or modified script was reviewed, executed, and its output checked by the authors against the raw records. After using this tool, the authors reviewed and edited the content as needed and take full responsibility for the content of the published article. All experimental computations and final reported values were independently checked by the authors against the released scripts and raw records.

REFERENCES

[1] OWASP Foundation, "API1:2023 Broken Object Level Authorization," OWASP API Security Top 10, 2023, accessed 18 September 2026. [Online]. Available: https://api-security.owasp.org/editions/2023/en/0xa1-broken-object-level-authorization/

[2] N. B. Chaleshtari, F. Pastore, A. Goknil, and L. Briand, "Metamorphic testing for web system security," *IEEE Transactions on Software Engineering*, pp. 3430–3471, 2023. [Online]. Available: https://doi.org/10.1109/TSE.2023.3256322

[3] P. X. Mai, F. Pastore, A. Goknil, and L. Briand, "Metamorphic security testing for web systems," in *2020 IEEE 13th International Conference on Software Testing, Validation and Verification (ICST)*, 2020, pp. 186–197. [Online]. Available: https://doi.org/10.1109/icst46399.2020.00028

[4] F. Liu, Y. Zhang, E. Li, W. Meng, Y.-Q. Shi, Q. Wang, and M. Yang, "Bacscan: Automatic black-box detection of broken-access-control vulnerabilities in web applications," in *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security*, 2025, pp. 1320–1333. [Online]. Available: https://doi.org/10.1145/3719027.3744825

[5] I. P. A. Dharmaadi, M. Alhanahnah, V.-T. Pham, F. Mohsen, and F. Turkmen, "Bacfuzz: Exposing the silence on broken access control vulnerabilities in web applications," *ArXiv*, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2507.15984

[6] C. Zuo, Q. Zhao, and Z. Lin, "Authscope: Towards automatic discovery of vulnerable authorizations in online services," in *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security*, 2017, pp. 799–813. [Online]. Available: https://doi.org/10.1145/3133956.3134089

[7] S. E. H. Chehade, F. Hantke, and B. Stock, "403 forbidden? ethically evaluating broken access control in the wild," in *2025 IEEE Symposium on Security and Privacy (SP)*, 2025, pp. 3218–3235. [Online]. Available: https://doi.org/10.1109/SP61157.2025.00252

[8] A. S. Filho, R. J. Rodríguez, and E. Feitosa, "Automated broken object-level authorization attack detection in rest apis through openapi to colored petri nets transformation," *International Journal of Information Security*, vol. 24, no. 2, 2025. [Online]. Available: https://doi.org/10.1007/s10207-024-00970-5

[9] H. Le, L. K. Shar, D. Bianculli, L. Briand, and D. C. Nguyen, "Automated reverse engineering of role-based access control policies of web applications," *Journal of Systems and Software*, vol. 184, p. 111109, 2022. [Online]. Available: https://doi.org/10.1016/j.jss.2021.111109

[10] B. Berger, R. W. Nguempnang, K. Sohr, and R. Koschke, "Static extraction of enforced authorization policies seeauthz," in *2020 IEEE 20th International Working Conference on Source Code Analysis and Manipulation (SCAM)*, 2020, pp. 187–197. [Online]. Available: https://doi.org/10.1109/SCAM51674.2020.00026

[11] W. Zhang, D. Bali, J. Kerney, A. Panda, and S. Shenker, "Extracting database access-control policies from web applications," in *20th USENIX Symposium on Operating Systems Design and Implementation (OSDI '26)*, 2026, pp. 249–270. [Online]. Available: https://www.usenix.org/conference/osdi26/presentation/zhang-wen

[12] Y.-Q. Shi, F. Liu, G. Yang, Y. Zhang, Y. Cao, E. Li, and S. Chen, "Facilitating access control vulnerability detection in modern java web applications with accurate permission check identification," *IEEE Transactions on Information Forensics and Security*, vol. 20, pp. 10 683–10 698, 2025. [Online]. Available: https://doi.org/10.1109/TIFS.2025.3614424

[13] Y. Huang, C. Shi, J. Lu, H. Li, H. Meng, and L. Li, "Detecting broken object-level authorization vulnerabilities in database-backed applications," in *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security*, 2024, pp. 2934–2948. [Online]. Available: https://doi.org/10.1145/3658644.3690227

[14] F. Liu, Y.-Q. Shi, Y. Zhang, G. Yang, E. Li, and M. Yang, "Mocguard: Automatically detecting missing-owner-check vulnerabilities in java web applications," in *2025 IEEE Symposium on Security and Privacy (SP)*, 2025, pp. 903–919. [Online]. Available: https://doi.org/10.1109/SP61157.2025.00010

[15] R. Feng, M. Zhang, A. Xia, J. Cheng, Y. Li, Y. Zhang, and Y. Liu, "Jauthguard: Automatic detection for broken access control in java web apis," in *2025 IEEE International Conference on Systems, Man, and Cybernetics (SMC)*, 2025, pp. 3102–3107. [Online]. Available: https://doi.org/10.1109/SMC58881.2025.11343625

[16] M. Schlaubitz, O. Veyisoglu, and M. Rennhard, "A2ct: Automated detection of function and object-level access control vulnerabilities in web applications," in *International Conference on Information Systems Security and Privacy*, 2025, pp. 425–436. [Online]. Available: https://doi.org/10.5220/0013092700003899

[17] P. Li, H. Chong, Y. Cao, and J. Yang, "Detecting privilege escalation in polyglot microservices via agentic program analysis," in *2026 IEEE Symposium on Security and Privacy (SP)*, 2026, pp. 1747–1765. [Online]. Available: https://doi.org/10.1109/SP63933.2026.00121

[18] V. Atlidakis, P. Godefroid, and M. Polishchuk, "Restler: Stateful rest api fuzzing," in *2019 IEEE/ACM 41st International Conference on Software Engineering (ICSE)*, 2019, pp. 748–758. [Online]. Available: https://doi.org/10.1109/ICSE.2019.00083

[19] A. Arcuri, M. Zhang, and J. P. Galeotti, "Advanced white-box heuristics for search-based fuzzing of rest apis," *ACM Transactions on Software Engineering and Methodology*, vol. 33, no. 6, pp. 1–36, 2024. [Online]. Available: https://doi.org/10.1145/3652157

[20] S. Seran, M. Zhang, O. Duman, and A. Arcuri, "Handling web service interactions in fuzzing with search-based mock-generation," *ACM Transactions on Software Engineering and Methodology*, vol. 35, no. 2, pp. 1–45, 2026. [Online]. Available: https://doi.org/10.1145/3731558

[21] Ömür Şahin, M. Zhang, and A. Arcuri, "Enhancing rest api fuzzing with access policy violation checks and injection attacks," *Journal of Systems and Software*, vol. 243, p. 113060, 2027. [Online]. Available: https://doi.org/10.1016/j.jss.2026.113060

[22] M. A. Uddin, S. Weerasinghe, C. Wojtak, T. Cerný, D. Silva-Junior, M. E. S. Ribeiro, and A. S. Abdelfattah, "Automated generation of microservice authorization tests using large language models," in *2026 International Conference on Service-Oriented System Engineering (SOSE)*, 2026, pp. 41–50. [Online]. Available: https://doi.org/10.1109/SOSE71128.2026.00014

[23] J. Sun, R. Tian, S. Zhao, X. Zhou, H. Wang, and Y. Zhang, "Llm-assisted idor detection in hospital mini-programs: Risks to pii and phi," in *2025 IEEE 24th International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*, 2025, pp. 2078–2086. [Online]. Available: https://doi.org/10.1109/Trustcom66490.2025.00242

[24] E. Wang, W. Xie, S. Li, R. Liu, Y. Zhou, Z. Wang, and B. Wang, "Large language model-powered protected interface evasion: Automated discovery of broken access control vulnerabilities in internet of things devices," *Sensors (Basel, Switzerland)*, vol. 25, no. 9, p. 2913, 2025. [Online]. Available: https://doi.org/10.3390/s25092913

[25] A. Wu, Z. Feng, R. Feng, Z. Xing, and Y. Liu, "Rethinking broken object level authorization attacks under zero trust principle," *ACM Transactions on Software Engineering and Methodology*, 2026. [Online]. Available: https://doi.org/10.1145/3833417

[26] H. Wang, Z. Wang, and P. Liu, "A hybrid llm workflow can help identify user privilege related variables in programs of any size," *ArXiv*, 2024. [Online]. Available: https://doi.org/10.48550/arXiv.2403.15723

[27] C. Wen, J. Cao, J. Su, Z. Xu, S. Qin, M. He, and C. Tian, "Enchanting program specification synthesis by large language models using static analysis and program verification," in *International Conference on Computer Aided Verification*, 2024, pp. 302–328. [Online]. Available: https://doi.org/10.1007/978-3-031-65630-9_16

[28] R. Wang, H. Zhuang, H. Cao, and S. Chen, "Measuring the reasoning boundaries of large language models for implicit security invariants in code: A controlled empirical study," in *2026 IEEE 50th Annual Computers, Software, and Applications Conference (COMPSAC)*, 2026, pp. 3146–3157. [Online]. Available: https://doi.org/10.1109/COMPSAC69091.2026.00467

[29] T. Le-Cong, B. Le, and T. Murray, "Can llms reason about program semantics? a comprehensive evaluation of llms on formal specification inference," in *Annual Meeting of the Association for Computational Linguistics*, 2025, pp. 21 991–22 014. [Online]. Available: https://aclanthology.org/2025.acl-long.1068/

[30] J. Liu, G. Lin, H. Mei, F. Yang, and Y. Tai, "Enhancing vulnerability detection efficiency: An exploration of light-weight llms with hybrid code features," *Journal of Information Security and Applications*, vol. 88, p. 103925, 2024. [Online]. Available: https://doi.org/10.1016/j.jisa.2024.103925

[31] J. Senanayake, H. Kalutarage, A. Petrovski, L. Piras, and M. O. Al-Kadri, "Defendroid: Real-time android code vulnerability detection via blockchain federated neural network with xai," *Journal of Information Security and Applications*, vol. 82, p. 103741, 2024. [Online]. Available: https://doi.org/10.1016/j.jisa.2024.103741

[32] R. Croft, M. A. Babar, and M. M. Kholoosi, "Data quality for software vulnerability datasets," in *2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE)*, 2023, pp. 121–133. [Online]. Available: https://doi.org/10.1109/ICSE48619.2023.00022

QIULONG LIN Qiulong Lin received the M.S. degree from Sogang University, Seoul, Republic of Korea. He is with Yango University, Fuzhou, China, and is also affiliated with Sogang University, Seoul, Republic of Korea. His research interests include Web/API security, vulnerability discovery, and metamorphic testing.

NANLEI CHEN Nanlei Chen is currently pursuing the M.S. degree at Sogang University, Seoul, Republic of Korea. He is with Yango University, Fuzhou, China. His research interests include Web/API security and authorization testing. He is the corresponding author of this work.